

IS FUNCTION STANDARD – IS INFORMATION SECURITY STANDARD

Cloud Security Standard

Table of Contents

1. Overview	2
1.1. Objective.....	2
1.2. Scope.....	2
1.3. Roles & Responsibilities	2
1.4. Definitions	2
1.5. Applicability of Requirements	3
2. Standard Requirements.....	4
2.1. Access Control.....	4
2.2. Awareness & Training	6
2.3. Configuration Management	7
2.4. Controls Assurance.....	7
2.5. Data Security.....	8
2.6. Incident Response	12
2.7. Network Management.....	13
2.8. Security Governance OR Asset Management	15
2.9. System Monitoring	15
2.10. System Acquisition & Development	17
2.11. System Integrity.....	17
2.12. Vendor Management	17
2.13. Vulnerability Management	18
3. Additional information	20
3.1. Shared responsibility.....	20
3.2. Other security standards	20
3.3. Containers security	20
4. Document Management	21
4.1. Effective Date.....	21
4.2. Exceptions.....	21
4.3. Compliance.....	21
4.4. Document Review	21
4.5. Storage.....	21
4.6. Contacts	21
5. References	21
5.1. Listing of related documents	21
6. Revisions	23

	STATUS Approved	SECURITY LEVEL Internal		
APPROVED (MAJOR CHANGE) 2025-10-22 Sumeet Parashar	DOCUMENT KIND Standard			
OWNING ORGANIZATION Corporate Information Security	DOCUMENT ID. 9AAD137817	REV. E	LANG. en	PAGE 1/23

1. Overview

ABB regards its information as a highly valuable asset. Information and information assets are critical to ABB and therefore require an adequate level of protection. Information must be protected to ensure that its confidentiality, integrity and availability are preserved throughout the lifecycle.

Cloud computing offers a number of potential advantages, including low costs, high performance and quick service delivery. However, because of the characteristics of the cloud service models, the deployment models, and the used technologies, the cloud services may introduce different risks exposure to an organization than on-premises solutions.

1.1. Objective

The purpose of this document is to supplement the [CFIS-CP-02 Information & Cyber Security Policy](#) and [Cloud Security Policy](#) with relevant security requirements.

This document is supported by various information security documents, as listed in Section 5 of this document.

1.2. Scope

This standard applies to any cloud services used to store, process or transmit ABB Information.

1.3. Roles & Responsibilities

- ABB functions and roles engaged in the selection, procurement, implementation, operation, and maintenance of cloud services are accountable and/or responsible for ensuring compliance with this standard. Some responsibilities may be delegated to third parties; however, the accountability remains with ABB.
- Cloud service providers are accountable for the secure delivery of their service, in accordance with contract requirements and the appropriate policies and standards.
- Cloud Subscription Owners are accountable for keeping their cloud environments secure and properly configured in line with this standard. This includes, but it is not limited to, handling vulnerabilities, controlling access, reducing unnecessary exposure to the internet, and collaborating with dedicated teams during security incidents.

1.4. Definitions

Each term defined in the [Information Security Glossary](#) appearing first time in this document is highlighted through a link.

- Cloud workload - Various tasks, applications, services, and processes run in cloud computing environments.

Note: Cloud workloads include: virtual machines, containers, PaaS (like for instance databases), serverless functions, and AI workloads.

- Cloud subscription - A logical container that provides access to cloud resources and services under a defined billing, identity, and policy boundary.

Note 1: Cloud subscription represents the primary unit for organizing, managing, and securing resources in a cloud environment.

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Approved	Internal	9AAD137817	E	en	2/23

Note 2: In Microsoft Azure, this is called a Subscription, in Google Cloud Platform (GCP), the equivalent concept is a Project, and in Amazon Web Services (AWS), the comparable construct is an Account.

- Cloud Subscription Owner - Individual who has full administrative control over a cloud subscription.

1.5. Applicability of Requirements

Before reading this document for the first time please familiarize yourself with the explanations below how to read this document in the right way.

The document defines security requirements for processing all types of information - from public to strictly confidential. However, different requirements are required for different types of information. For instance, some requirements are mandatory only for processing strictly confidential information. For this purpose, the following abbreviations are used in this document:

- SC – Strictly Confidential, C – Confidential, I – Internal and P - Public. For more information regarding the information classification, please see the [Information Classification and Handling Policy](#).
- M - Mandatory, R – Recommended, and O – Optional. Mandatory requirements must be implemented. Non-compliance requires an exception. Recommended requirements are suggested to be implemented, but they are not mandatory. Missing recommended requirements do not require raising an exception request. Optional requirements are not expected to be implemented, but it is not forbidden to do so.

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Approved	Internal	9AAD137817	E	en	3/23

2. Standard Requirements

2.1. Access Control

		Information type				Applicable for		
	Requirement	P	I	C	SC	IaaS	PaaS	SaaS
2.1.1	The cloud service provider must provide user registration and deregistration capabilities as well as access rights management capabilities, and specifications for the use of these capabilities to ABB.	M	M	M	M	x	x	x
2.1.2.	Authentication processes must be based on the ABB-managed Identity Management solution. Note: Using ABB Active Directory or ABB Azure Active Directory is allowed. Using external identity providers is not allowed.	R	R	M	M	x	x	x
2.1.3	Authentication processes of the Internet-faced application must be integrated with ABB Azure Active Directory. Note: Control applies to applications as well as to other IT Assets in the cloud environment.	O	M	M	M	x	x	x
2.1.4	Access to Internet facing applications must use multi-factor authentication (MFA).	O	M	M	M	x	x	x
2.1.5	Access to ABB IT Assets must granted based on need to know and least-privilege principle.	O	M	M	M	x	x	x
2.1.6	Applications must implement Role Based Access Control.	O	O	R	R	x	x	x

STATUS Approved	SECURITY LEVEL Internal	DOCUMENT ID. 9AAD137817	REV. E	LANG. en	PAGE 4/23
--------------------	----------------------------	----------------------------	-----------	-------------	--------------

2.1.7	User accounts must be reviewed annually to identify any irregularities such as redundant, expired or inactive accounts.	O	M	M	M	x	x	x
2.1.8	Access rights must be reviewed at least every 90 days. Note: The access review is a secondary control for the primary controls following the need-to-know principle and proper joiner/mover/leaver processes. The goal of this safeguard is to identify any potential incorrect access or incorrect access rights (e.g., too broad) and apply appropriate measures for all identified discrepancies.	O	O	R	R	x	x	x
2.1.9	Web API (Application Programming Interface) calls must be authenticated using strong authentication such as token-based standards (e.g., OpenID Connect, SAML) or digital certificates. Note 1: The unencrypted authentication based on a pair login name and password is not allowed, as it exposes the password and hence permits unauthorized access or service usage. This kind of authentication is usually called "basic authentication". Please note that encoding password with Base64 is not an encryption method. Note 2: The API Authentication Standard defines allowed authentication methods. Note 3: To learn more about API authentication, please familiarize with the Guideline on API Authentication Best Practices .	R	R	R	R	x	x	x
2.1.10	Web API (Application Programming Interface) calls must be authenticated using encrypted channels. Note: Password cannot be transmitted in clear text without additional protection to avoid eavesdropping.	M	M	M	M	x	x	x
2.1.11	Privileged access to the servers must be only permitted through ABB PAM solution or Jump Server solution.	M	M	M	M	x	N/A	N/A

STATUS Approved	SECURITY LEVEL Internal	DOCUMENT ID. 9AAD137817	REV. E	LANG. en	PAGE 5/23
--------------------	----------------------------	----------------------------	-----------	-------------	--------------

2.1.12	Anonymous access must be denied.	O	M	M	M	x	x	x
2.1.13	ABB must always retain administrative access over the cloud subscription administration console.	M	M	M	M	x	x	N/A
2.1.14	Third parties access to the cloud subscription administration console is only allowed when the following conditions are met: - if it is required to fulfill the requirement of their contractual obligations to ABB, - limited to need to have features, and - without the right to remove main ABB administrator. Note: For justified business needs, the same subscription administration console might be used for more than one service provider, but all requirements above must be fulfilled.	M	M	M	M	x	x	N/A
2.1.15	The following controls must be implemented to the cloud subscription's administration console: - access restricted based on the principle of least privilege, - authentication integrated with ABB Azure Active Directory, - multi-factor authentication enforced, and - IP address filtering rules in place, to restrict from where access could be allowed to the console and to the cloud API is permitted. Note: IP address filtering rules might include some (sub)networks.	R	R	M	M	x	x	N/A

2.2. Awareness & Training

		Information type	Applicable for
--	--	------------------	----------------

STATUS Approved	SECURITY LEVEL Internal	DOCUMENT ID. 9AAD137817	REV. E	LANG. en	PAGE 6/23
--------------------	----------------------------	----------------------------	-----------	-------------	--------------

	Requirement	P	I	C	SC	IaaS	PaaS	SaaS
2.2.1	The cloud service provider must provide awareness, education and training for its employees, and request contractors to do the same, concerning the appropriate handling of customer data.	M	M	M	M	x	x	x

2.3. Configuration Management

		Information type				Applicable for		
	Requirement	P	I	C	SC	IaaS	PaaS	SaaS
2.3.1	IT Assets managed by Cloud Service Provider must be hardened in accordance with the best security practices.	M	M	M	M	N/A	x	x
2.3.2	IT Assets managed by ABB must be hardened in accordance with ABB hardening baselines. Note 1: It covers operating system, middleware (databases, runtime environments, etc.), and applications. Note 2: Hardening baselines documents, including cloud-specific ones, are accessible here .	M	M	M	M	x	N/A	N/A

2.4. Controls Assurance

		Information type				Applicable for		
	Requirement	P	I	C	SC	IaaS	PaaS	SaaS
2.4.1	Use of cloud services must comply with all applicable laws. Note: Examples of such regulations are Sarbanes–Oxley Act (SOX), privacy-related regulations (e.g., General Data Protection Act (GDPR), California Consumer Privacy Act (CCPA)), classified information regulations (e.g., NIST SP 800-171).	M	M	M	M	x	x	x

STATUS Approved	SECURITY LEVEL Internal	DOCUMENT ID. 9AAD137817	REV. E	LANG. en	PAGE 7/23
--------------------	----------------------------	----------------------------	-----------	-------------	--------------

2.5. Data Security

		Information type				Applicable for		
	Requirement	P	I	C	SC	IaaS	PaaS	SaaS
2.5.1	Data must be processed and stored only in cloud regions agreed with ABB or selected by ABB in accordance with the applicable laws and regulations. Note 1: Cloud regions are a common term used by CSPs to determine actual geographic location where cloud physical resources are located. The selection of the most appropriate cloud regions may depend on many factors, including compliance and security, cost, latency, as well as available services and their features. Note 2: The application onboarding must be preceded with the selection of the best region to fulfill mentioned factors. For instance, system processing EU citizens information should be rather located in EU borders (due to GDPR) than outside.	O	O	M	M	x	x	x
2.5.2	Data at rest must be encrypted. Note: This requirements does specify how exactly encryption must be applied. Different options are available, like file-based encryption, full disk encryption, database encryption, and others. Please note that other more specific encryption requirements are defined in that this document as well.	O	R	M	M	x	x	x
2.5.3	Data in transit must be encrypted Note 1: It encompasses all network traffic, including network traffic to and from databases, to and from web servers, as well as API calls. Note 2: Passwords are classified as confidential information, thus the process of user authentication is regarded as the transmission of confidential information.	O	R	M	M	x	x	x
2.5.4	Data in use must be encrypted. Note: In-use encryption might be seen as an extension to encryption data at rest and data in transit. It requires specific hardware. This kind of security protection is relatively new, compared to data in transit and data at rest encryption.	O	O	O	R	x	x	x

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Approved	Internal	9AAD137817	E	en	8/23

2.5.5	The following cryptographic algorithms must be used to encrypt strictly confidential information: - AES-256 - RSA-2048 or higher - ECC 224 or higher Note: If any security controls require to encrypt data, those cryptographic algorithms must be used. This point does not say in which cases encryption must be used; it only specifies allowed algorithms.	O	O	O	M	x	x	x
2.5.6	The following cryptographic algorithms must be used to encrypt confidential information: - AES-128 or higher - RSA-2048 or higher - ECC 224 or higher Note: If any security controls require to encrypt data, those cryptographic algorithms must be used. This point does not say in which cases encryption must be used; it only specifies allowed algorithms.	O	O	M	N/A	x	x	x
2.5.7	The following hash algorithms must be used to protect the integrity of internal, confidential or strictly confidential information: When hash algorithm must be used to protect the information integrity, the following ones are allowed: - SHA-2-256 or higher Note: If there is a need to hash data to protect information integrity, only those cryptographic algorithms must be used. This point does not say in which cases hashing must be used; it only specifies allowed algorithms.	M	M	M	M	x	x	x
2.5.8	Encryption keys used to encrypt strictly confidential and confidential data must be stored only in Hardware Secure Modules (HSMs) • validated for FIPS 140-2 Level 3 or FIPS 140-3 Level 3. Note 1: FIPS 140-2 and FIPS 140-3 defines 4 levels of security – Level 1, 2, 3, and 4. FIPS 140-2 is being expired and those certificates are valid until September 2026. Note 2: FIPS 140-2 level 3 certification includes all the requirements of Level 2 but adds additional physical security measures to protect against unauthorized access and tampering. This typically involves features such as tamper-evident coatings, seals, or	O	O	M	M	x	x	x

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Approved	Internal	9AAD137817	E	en	9/23

	enclosures, as well as sensors or mechanisms that trigger self-destruct mechanisms if tampering is detected.							
2.5.9	Withdrawn, incorporated into 2.5.8.	-	-	-	-	-	-	-
2.5.10	Encryption keys used to encrypt strictly confidential information must - for cloud services approved by ABB (Microsoft Azure, Amazon Web Services, Google Cloud Computing, and O365 with Microsoft Purview protection) use the following strategy: - Hold Your Own Key (HYOK), or - Bring Your Own Key (BYOK) imported into single-tenant cloud HSM, or - Customer Generated Key (CGK) imported into single-tenant cloud HSM. - for other cloud services: follow Hold Your Own Key (HYOK) strategy. Note 1: HYOK (Hold Your Own Key) is a key management strategy where an organization maintain exclusive control over encryption keys. Unlike BYOK, where keys are managed externally but used to encrypt data stored in the cloud, HYOK involves keeping encryption keys entirely within the organization's premises or trusted infrastructure. This approach provides maximum security over key management. In certain cases it may be required to fulfill regulation requirement. Note 2: BYOK (Bring Your Own Key) is a key management strategy where an organization retain ownership and control over encryption keys used to protect their data stored in a cloud environment. Instead of relying on the cloud service provider for key generation and management, organization brings their own keys. In certain cases it may be required to fulfill regulation requirement. Note 3: CGK (Customer Generated Key) is a key management strategy where a customer creates cryptographic key in the cloud ensuring the customer retains complete control over the key's lifecycle and security.	O	O	O	M	x	x	N/A

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Approved	Internal	9AAD137817	E	en	10/23

2.5.11	Encryption keys used to encrypt confidential information must follow ○ Hold Your Own Key (HYOK), or ○ Bring Your Own Key (BYOK) where keys are imported into single- or multitenant cloud HSM, or ○ Customer Generated Key (CGK) where keys are imported into single- or multitenant cloud HSM. Note 1: See 2.5.10	O	O	M	N/A	x	X	N/A
2.5.12	Encryption keys used to encrypt ABB data must not be used for any other customers.	O	O	M	M	x	X	x
2.5.13	Access to the encryption keys must be granted only on a need-to-know basis.	O	O	M	M	x	x	x
2.5.14	Encryption keys must be rotated every 24 months, at least. Note 1: Encryption keys must be archived in order to be able to restore old backups. ABB's standard solution for key management supports this feature. Note 2: Envelope encryption (also known as wrapped encryption) uses two different keys: a Key Encryption Key (KEK) and a Data Encryption Keys (DEK). For envelope encryption, only the rotation of the KEK is required, while the DEK may remain the same, as its rotation might have negative performance impact. Note 3: For databases, key rotation for application-based and column-based encryption is prone to impact performance during the operation. Therefore, neither application-based nor column-based encryption is recommended.	O	O	M	M	x	x	x
2.5.15	Attached and detached disks (boot and non-boot volumes) of virtual machines must be encrypted. Note: Virtual machines must be classified on confidentiality based on the contained information.	O	O	M	M	x	N/A	N/A
2.5.16	All snapshots must be encrypted. Note: Snapshots must be classified on confidentiality based on the contained information.	O	O	M	M	x	N/A	N/A

STATUS Approved	SECURITY LEVEL Internal	DOCUMENT ID. 9AAD137817	REV. E	LANG. en	PAGE 11/23
--------------------	----------------------------	----------------------------	-----------	-------------	---------------

2.5.17	Databases must be encrypted. Note 1: Databases must be classified on confidentiality based on the contained information. Note 2: Database encryption is usually implemented in the form of Transparent Database Encryption (sometimes named Native Encryption). Typically the Key Encryption Key (KEK) is used to encrypt the Data Encryption Key (DEK). The Data Encryption Key remains unchanged during the lifecycle of the database, while the Key Encryption Key is rotated in accordance with the applicable regulations. Note 3: Encrypting database file(s) (known as file-based encryption) does not fulfil this requirement. Note 4: Application-level encryption may fulfill this requirement if the application level encryption key is stored in a Hardware Security Module (HSM).	O	O	M	M	x	N/A	N/A
--------	--	---	---	---	---	---	-----	-----

2.6. Incident Response

		Information type				Applicable for		
2.6	Requirement	P	I	C	SC	IaaS	PaaS	SaaS
2.6.1	The cloud service provider must provide secure mechanisms for: – the cloud service provider to report an information security incident to a cloud service customer; – the cloud service customer to report an information security incident to the cloud service provider and track its status	M	M	M	M	x	x	x
2.6.2	The cloud service provider must provide contact information for information security incident response.	M	M	M	M	x	x	x

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Approved	Internal	9AAD137817	E	en	12/23

2.7. Network Management

	Requirement	Information type				Applicable for		
		P	I	C	SC	IaaS	PaaS	SaaS
2.7.1	The cloud service provider must enforce network segregation between the cloud service provider's internal administration environment and the cloud service customer's cloud computing environment.	M	M	M	M	x	x	x
2.7.2	The cloud service provider must enforce network segregation between tenants in a multi-tenant environment. Note 1: Network segregation can be implemented as logical or physical separation. Both methods are allowed. Note 2: Using multi-tenant environment for processing strictly confidential information is not allowed.	M	M	M	N/A	x	x	x
2.7.3	Dual-DMZ architecture must be applied (External DMZ (EDMZ) and Internal DMZ (IDMZ)).	M	M	M	M	x	N/A	N/A
2.7.4	Backend services must not be reachable directly from the Internet excluding PaaS in the following scenarios: - incoming traffic is filtered (e.g., IP-filtering), or - multifactor authorization (MFA) is enforced, or - only public information is stored and processed, or - access is time limited only to create and/or configure a service for the first time. Note: Backend services include, among others, databases and application server.	M	M	M	M	x	x	x
2.7.5	DMZ must apply micro-segmentation principle. Note: To learn more micro-segmentation, please refer to the Network Security Standard .	R	R	R	R	x	N/A	N/A
2.7.6	Integration of cloud application with on-premises ABB resources must be implemented by a dedicated cloud connection, ABB Virtual Private Network (VPN) service, integration platform or connector software, all of which need ABB approval. Note: A dedicated cloud connection is a private connection to the cloud service provider's network (for instance Azure ExpressRoute, AWS Direct Connect, and Google Cloud Interconnect).	M	M	M	M	x	x	x

STATUS Approved	SECURITY LEVEL Internal	DOCUMENT ID. 9AAD137817	REV. E	LANG. en	PAGE 13/23
--------------------	----------------------------	----------------------------	-----------	-------------	---------------

	Requirement	Information type				Applicable for		
		P	I	C	SC	IaaS	PaaS	SaaS
2.7.7	Internet-facing web applications must be protected by the Web Application Firewall (WAF) solution or an equivalent solution. Note: This requirement applies to cloud service providers.	M	M	M	M	N/A	N/A	x
2.7.8	Internet-facing web applications must be protected by the ABB standard Web Application Firewall (WAF) security service. Note 1: This requirement applies to applications where infrastructure is managed by ABB. Note 2: The current ABB standard Web Application Firewall (WAF) solution is Akamai WAF.	M	M	M	M	x	x	N/A
2.7.9	HTTP/HTTPS outbound traffic must be filtered by the ABB standard Secure Web Gateway solution. Note 1: This requirement applies to traffic initiated both from the Corporate Network and cloud networks. Note 2: Terms "Secure Web Gateway" and "Global Proxy Solutions" can be used interchangeably.	M	M	M	M	x	N/A	N/A
2.7.10	Traffic to and from cloud environment must pass through Intrusion Prevention System (IPS) or equivalent security measure unless it is subject to Secure Web Gateway (SWG) or Web Application Firewall (WAF) inspection. Note: It applies to communication between cloud environment and ABB as well as cloud environment and Internet.	M	M	M	M	x	N/A	N/A
2.7.11	No outdated or known compromised protocol or version of a protocol must be used. Note 1: Network protocols where credentials are transferred without encryption are not allowed. For instance, telnet and FTP cannot be used without additional safeguards. Note 2: Vulnerable protocols or versions of protocols (like SSL 3.0, TLS 1.0, and TLS 1.1) are not allowed. SSL is superseded by TLS. Note 3: The security of protocols depends on the use of secure cryptographic controls.	M	M	M	M	x	x	x
2.7.12	TLS protocol must be used in the version 1.2 or higher	M	M	M	M	x	x	x

STATUS Approved	SECURITY LEVEL Internal	DOCUMENT ID. 9AAD137817	REV. E	LANG. en	PAGE 14/23
--------------------	----------------------------	----------------------------	-----------	-------------	---------------

		Information type				Applicable for		
	Requirement	P	I	C	SC	IaaS	PaaS	SaaS
	Note 1: This requirement covers transfer to the cloud environment during the migration as well. Note 2: TLS protocols must support only allowed cryptographic algorithms. Note 3: Passwords are classified as confidential, thus the process of user authentication is treated as transmission of confidential information.							
2.7.13	Management and monitoring interfaces of ABB IT Assets must not be reachable directly from the Internet.	M	M	M	M	x	N/A	N/A

2.8. Security Governance

		Information type				Applicable for		
	Requirement	P	I	C	SC	IaaS	PaaS	SaaS
2.8.1	IT Assets must be registered in the ABB Asset Inventory with all relevant data in accordance with the Information Security Asset Management Policy.	M	M	M	M	x	x	x

2.9. System Monitoring

		Information type				Applicable for		
	Requirement	P	I	C	SC	IaaS	PaaS	SaaS
2.9.1	IT Assets must be configured to log all security related events.	M	M	M	M	N/A	x	x
2.9.2	IT Assets must be configured to log all security related events as per the requirements of the Monitoring and Logging Standard .	M	M	M	M	x	N/A	N/A

STATUS Approved	SECURITY LEVEL Internal	DOCUMENT ID. 9AAD137817	REV. E	LANG. en	PAGE 15/23
--------------------	----------------------------	----------------------------	-----------	-------------	---------------

2.9.3	All sources of logs must be configured to store dates and times in Coordinated Universal Time (UTC) format.	R	R	R	R	x	x	x
2.9.4	Configured retention period for collected security logs must be not less than 1 year (unless it would violate laws or regulations). Note: Logs may be collected for different reasons; thus, different logs may be stored with different retention periods. The minimum set of security logs is listed in the Monitoring and Logging Standard .	M	M	M	M	x	x	x
2.9.5	Logs must be monitored. IT Assets must be configured to integrate with the ABB log collecting tool. Note 1: It includes cloud native IT Assets like cloud subscription administration console. Note 2: The timeline and the scope of application logging must be discussed and agreed with ABB's Threat Detection and Engineering Team. Note 3: Automated logs monitoring is the most cost-effective way to comply with this requirement. Note 4: It is expected that the applicability of this requirement might be extended in the future.	O	R	M	M	x	N/A	N/A
2.9.6	All ABB owned public clouds subscriptions and workloads hosted within ABB owned tenants must be integrated with ABB-approved Cloud Security Posture Management (CSPM) solution. Note 1: CSPM solution helps secure cloud environments by identifying and reporting misconfigurations, vulnerabilities, and compliance issues. CSPM continuously monitors cloud services, automates security checks and provides real-time visibility. Note 2: ABB selected Wiz as its CSPM solution. For more information, please refer to Introduction to CSPM (Mitigating Risks in Public Cloud) . Note 3: CSPM integrates with cloud subscriptions using API. When integrated, all cloud workloads within a given subscriptions are integrated with CSPM automatically. Note 4: The term cloud subscriptions is used in Azure, GCP uses the term "projects", and AWS uses the term "account".	M	M	M	M	x	x	N/A
2.9.6.A	All Kubernetes clusters deployed in public cloud environments must have runtime threat detection technology deployed and enabled. Note 1: ABB selected Wiz Sensor agent as its runtime threat detection solution for Kubernetes clusters. Note 2: Kubernetes clusters are integrated with Wiz via API. The Wiz Sensor is a feature within the Wiz platform that provides additional runtime threat detection capabilities. To learn more, refer to Kubernetes Clusters - Wiz Sensor (CWPP) . To deploy Wiz Sensor on Kubernetes Cluster, submit a request Kubernetes Cluster - Wiz Sensor - SNOW Catalog Item .	M	M	M	M	x	x	N/A

STATUS Approved	SECURITY LEVEL Internal	DOCUMENT ID. 9AAD137817	REV. E	LANG. en	PAGE 16/23
--------------------	----------------------------	----------------------------	-----------	-------------	---------------

2.10. System Acquisition & Development

		Information type				Applicable for		
	Requirement	P	I	C	SC	IaaS	PaaS	SaaS
2.10.1	Production and non-production (e.g., development, testing) environments must be physically or logically separated.	R	M	M	M	x	x	x
2.10.2	Production data must not be replicated to or used in non-production environments unless, a) data is tokenized or anonymized, or b) exactly the same level of protection is applied to the test environment as to the production environment.	O	R	M	M	x	x	x

2.11. System Integrity

		Information type				Applicable for		
	Requirement	P	I	C	SC	IaaS	PaaS	SaaS
2.11.1	All components of the cloud environment must be patched in timely manner. Note: It covers, but is not limited to, operating systems, middleware (like runtime environments or databases), applications, hypervisors, and containers.	M	M	M	M	N/A	x	x
2.11.2	All components of the cloud environment must be patched in accordance with the Security Patch Management Policy . Note: It covers, but is not limited to, operating systems, middleware (like runtime environments or databases), applications, hypervisors, and containers.	M	M	M	M	x	N/A	N/A

2.12. Vendor Management

		Information type				Applicable for		
	Requirement	P	I	C	SC	IaaS	PaaS	SaaS

STATUS Approved	SECURITY LEVEL Internal	DOCUMENT ID. 9AAD137817	REV. E	LANG. en	PAGE 17/23
--------------------	----------------------------	----------------------------	-----------	-------------	---------------

2.12.1	Cloud service providers and cloud service must pass an Information Security Risk Assessment encompassing cloud-specific technologies and controls.	M	M	M	M	x	x	x
2.12.2	The relevant non-disclosure agreements (NDA), Data Protection Agreements (DPA) and Technical & Organization Measure (TOM) must be signed with the cloud service providers and other third parties before the access to data is provided.	M	M	M	M	x	x	x
2.12.3	The cloud service provider must provide evidence to ABB to substantiate its claim of implementing information security controls by providing one of the following: - ISO 27001 certificate or - SOC 2 type 2 report. The scope of purchased cloud service must be in scope of the provided documents.	R	R	M	M	x	x	x

2.13. Vulnerability Management

		Information type				Applicable for		
	Requirement	P	I	C	SC	IaaS	PaaS	SaaS
2.11.3	Systems must be periodically checked against known vulnerabilities in accordance with best industry practices. Note 1: Often the process is supported with automated tools which might be agent-less or agent-based or both. Note 2: Usually the process or tool utilize well-recognized security vulnerability databases (e.g., CVE). Note 3: Penetration tests are not considered as component of the vulnerability management process.	M	M	M	M	N/A	x	x
2.11.4	Corporate vulnerability agent must be installed and/or server scanned in accordance with the Threat and Vulnerability Management Policy .	M	M	M	M	x	N/A	N/A
2.11.5	Systems must be periodically checked against known vulnerabilities in accordance with the Threat and Vulnerability Management Policy . Note: Vulnerability Management Process includes, among others, checking if software is up to date.	M	M	M	M	x	N/A	N/A

STATUS Approved	SECURITY LEVEL Internal	DOCUMENT ID. 9AAD137817	REV. E	LANG. en	PAGE 18/23
--------------------	----------------------------	----------------------------	-----------	-------------	---------------

		Information type				Applicable for		
	Requirement	P	I	C	SC	IaaS	PaaS	SaaS
2.11.6	All identified vulnerabilities must be remediated in timely manner in accordance with the Threat and Vulnerability Management Policy .	M	M	M	M	x	N/A	N/A
2.11.7	ABB standard endpoint protection solution must be installed on endpoints.	M	M	M	M	x	N/A	N/A
2.11.8	Application whitelisting solution must be in place. Note: Application whitelisting blocks unauthorized or unknown applications from executing. Only allowed executable files that are explicitly approved and whitelisted are permitted to be stored and executed on Virtual Machines.	O	O	O	R	x	N/A	N/A

STATUS Approved	SECURITY LEVEL Internal	DOCUMENT ID. 9AAD137817	REV. E	LANG. en	PAGE 19/23
--------------------	----------------------------	----------------------------	-----------	-------------	---------------

3. Additional information

3.1. Shared responsibility

Cloud services and technologies utilized by the cloud services are subject to the same control requirements as prescribed by the complete set of the **ABB Information Security Policies and Standards**. The responsibility for the implementation of the Information Security requirements in the Cloud Solution depends on the ownership and is divided between ABB and the cloud service providers in accordance with the respective cloud model. A typical division of responsibilities for the implementation of controls is based on the cloud service models and provided in the **Cloud Computing in ABB** in the section Cloud Service Models.

3.2. Other security standards

This document defines security requirements that are or especially important in cloud environments. However, this document only complements other Information Security Policies and Standards. Readers should especially look at the following documents:

- Antimalware protections is important safeguard for IaaS and is covered in the Server Security Policy. The goal is to protect virtual machines from malicious software using dedicated security solution capable to detect and stop malware infection.
- Backups are necessary to ensure data availability. Backup and Archiving Standard defines respective requirements.

3.3. Containers security

This document does not cover containers directly. The existing security requirements are applicable in general, but they are not focused on the containers context. The **Guideline on Containers and Container Orchestration Security** is a useful document to provide recommendation on security for containers and container orchestrators like Kubernetes.

InfoSec Policies and Standards are supported by **hardening baselines** that are mandatory configurations to be implemented on variety of IT Assets. ABB hardening baselines serve as a starting point for ensuring consistent security posture across an company's IT environment. Among others, hardening baselines are provided for Azure, AWS and GCP cloud services.

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Approved	Internal	9AAD137817	E	en	20/23

4. Document Management

4.1. Effective Date

The standard is effective as of its release date.

There are grace periods for new requirements:

- Point 2.9.6 – CSPM – no grace period.
- Point 2.9.6.A – Wiz Agent for Kubernetes Clusters – 2026-04-30.

4.2. Exceptions

Any exceptions to this standard must be managed in accordance with the [Information Security Exception Policy](#).

4.3. Compliance

Non-compliance with this standard may initiate consequence actions in accordance with the [CFIS-CP-02 Information & Cyber Security Policy](#).

4.4. Document Review

This document is reviewed and updated in accordance with the [Information Security Document Lifecycle Policy](#).

4.5. Storage

The authorized copy of this document is published in the [ABB Library](#). Access to this document is deliberately provided to all End Users.

4.6. Contacts

For questions concerning this document please contact the [Global Information Security Policies and Standards](#).

5. References

5.1. Listing of related documents

Ref #	Document Kind, Title	Document No.
1	CFIS-CP-02 Information & Cyber Security Policy	7ABA146012
2	Cloud Security Policy	9AAD129745
3	Information Classification and Handling Policy	9AAD125412

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Approved	Internal	9AAD137817	E	en	21/23

Ref #	Document Kind, Title	Document No.
4	Information Security Asset Management Policy	9AAD125534
5	Information Security Exception Policy	9AAD129606
6	Security Patch Management Policy	9AAD137561
7	Threat and Vulnerability Management Policy	9AAD126293
8	Information Security Document Lifecycle Policy	9AAD129603
9	Monitoring and Logging Standard	9AAD127113
10	Hardening Baselines (access is limited)	(site)
11	Guideline on Containers and Container Orchestration Security	9AAD138077
12	API Authentication Standard	9AAD140227
13	Guideline on API Authentication Best Practices	9AAD140182
14	Information Security Glossary	9AAD129610
15	Introduction to CSPM (Mitigating Risks in Public Cloud)	N/A
16	Kubernetes Clusters - Wiz Sensor (CWPP)	N/A

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Approved	Internal	9AAD137817	E	en	22/23

6. Revisions

Rev.	Page (P) Chapt. (C)	Description	Date Dept./Init.
A	All	Initial Revision	2021-10-11 – IS SEC / OSZ
B	1.5 3.1 All 2.11.4 2.11.6 3.2	Minor change: Section updated (grace period expired) Minor change: Typos fixed Minor change: Content reviewed and updated due to grace period expiration Minor change: Hyperlink added Minor change: Wording updated	2021-12-05 – IS SEC / JR
C	2.11.6 1.5, 2.3	Minor change: Point removed as it was duplicate to point 2.11.4 Minor change: reference to already expired grace period removed	2023-01-03 – IS SEC / JR
D	2.1.9 2.5.4 2.5.8, 2.5.9 2.5.10, 2.5.11 2.7.4 2.11.8 3 4.3 All	Minor change: references added to the API Authentication Standard and Guideline on API Authentication Best Practices. Minor change: recommendation on encryption of data in use added. Minor change: clarifying and simplifying the requirements regarding the Hardware Security Module Withdrawn and incorporated into 2.5.8. Key management requirements changed. Exceptions for PaaS built into this requirement. Minor change: application whitelisting recommendation added Minor change: section “Additional information” with the reference to: 1) the Guideline on Containers and Container Orchestration Security, and 2) hardening baselines. Minor change: section “Compliance” added. Other minor changes	2024-03-08 – IS SEC / OSZ
E	1.3 2.9.6 2.9.6.A 3.1 3.2 All	Adding a role of cloud subscription owners New requirement on integration of cloud subscriptions with CSPM added New requirement on deploying Wiz Sensor Agent in Kubernetes clusters added Explanatory sub-section “Shared responsibility” added Explanatory sub-section “Other security standard ” added Other minor changes	2025-10-22 – IS SEC / OSZ

STATUS	SECURITY LEVEL	DOCUMENT ID.	REV.	LANG.	PAGE
Approved	Internal	9AAD137817	E	en	23/23